

# SIMATS ENGINEERING

## ASSESSMENT TOOL 2 – VULNERABILITY ASSESSMENT REPORT

### Course: Ethical Hacking (ITA14)

Course Outcome: CO4 – Network Security Testing and Wireless Security

Prepared as answers for the Annexure A case studies

The uploaded assessment contains ten wireless-security incident case studies. The answers below follow the assessment rubric: incident background and technical understanding, wireless vulnerability identification, risk/impact/root-cause analysis, security recommendations, and evidence/report quality. The incident facts are based on the supplied assessment document; technical controls and mitigation recommendations use standard cybersecurity practice.

### Risk Rating Summary

| Case                               | Primary Risk                                                | Likelihood  | Impact      |
|------------------------------------|-------------------------------------------------------------|-------------|-------------|
| 1. TJX Wireless Breach             | Obsolete encryption, segmentation and payment-data exposure | High        | Critical    |
| 2. Lowe's Wireless Intrusion       | Wireless-to-corporate network access                        | High        | Critical    |
| 3. Firesheep / Public Wi-Fi        | Session hijacking and credential/session exposure           | High        | High        |
| 4. DarkHotel                       | Malicious hotel Wi-Fi/update delivery                       | Medium–High | Critical    |
| 5. Marriott Deauthentication       | Availability attack using management frames                 | High        | Medium–High |
| 6. Fake Wi-Fi at RNC               | Evil-twin networks and user information exposure            | High        | High        |
| 7. Anti-Doping Officials           | Credential theft and sensitive-data access                  | Medium–High | Critical    |
| 8. OPCW Wi-Fi Intrusion Attempt    | Close-access wireless compromise                            | Medium      | Critical    |
| 9. Australian Airport Evil Twin    | SSID impersonation and personal-data capture                | High        | High        |
| 10. Network Rail Portal Compromise | Compromised administrator account                           | Medium–High | High        |

# 1. TJX Companies Wireless Network Breach, 2005–2007

## 1. Incident Background and Technical Understanding

TJX Companies suffered a major payment-card data breach after attackers gained unauthorized wireless access to the retail network. The assessment states that TJX was using WEP while transitioning to WPA and lacked adequate controls to restrict wireless access. The incident demonstrates how weak wireless encryption, insufficient monitoring, poor segmentation, and insecure handling of sensitive information can combine to create a serious compromise.

### Wireless Encryption Vulnerabilities

WEP is obsolete and does not provide adequate protection against modern attacks. Continuing to operate WEP during a migration increased the probability that attackers could obtain wireless access and move into internal systems. A secure enterprise environment should use WPA2-Enterprise or WPA3-Enterprise with strong cryptography and centralized authentication.

### Authentication and Access Control

Wireless access should be authenticated using enterprise identity controls rather than shared credentials. 802.1X with an appropriate EAP method, device/user identity, certificate validation, and account lifecycle management reduces unauthorized access.

### Network Segmentation

Wireless clients should not have unrestricted access to payment-processing systems. Retail wireless, corporate systems, point-of-sale devices, guest devices, and payment environments should be separated using VLANs, firewalls, access-control rules, and least-privilege policies.

### Monitoring and Payment-Data Protection

Wireless intrusion detection/prevention, centralized logging, network traffic monitoring, and alerting should identify rogue access points, unusual associations, lateral movement, and suspicious payment-data traffic. PCI DSS controls should be applied to the cardholder-data environment.

### Risk and Impact

Likelihood: High. Impact: Critical. Potential effects include payment-card theft, financial loss, regulatory penalties, incident-response costs, customer harm, and reputational damage. The main root causes were obsolete encryption, inadequate wireless restrictions, weak segmentation, and insufficient monitoring.

### Recommendations

Complete the migration from WEP; use WPA2-Enterprise/WPA3-Enterprise; deploy 802.1X and centralized authentication; segment payment systems; deploy rogue-AP detection/WIDS/WIPS; encrypt sensitive traffic end-to-end; minimize stored card data; continuously monitor access; and maintain PCI DSS-aligned controls and periodic wireless assessments.

### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.

- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 2. Lowe's Wireless Network Intrusion, 2003

### 1. Incident Background and Technical Understanding

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. According to the assessment, the wireless connection provided access to central systems and other retail locations, and the attackers attempted to install software designed to capture customers' credit-card information. The central security failure was the ability of a local wireless compromise to reach broader corporate resources.

### Wireless Authentication and Isolation

Wireless clients should be strongly authenticated and isolated from sensitive internal systems. Guest or local wireless access must never provide direct, broad access to corporate resources.

### Firewall and Segmentation Weakness

The architecture should enforce firewalls and access-control rules between wireless networks, store networks, corporate services, and point-of-sale systems. A compromised wireless client should be treated as untrusted.

### Point-of-Sale Protection

POS systems should be placed in dedicated protected network segments with only the required communication paths. Administrative access should be restricted and monitored.

### Intrusion Detection and Centralized Access Management

IDS/IPS, wireless monitoring, centralized authentication, and security logging can detect abnormal wireless associations, lateral movement, unauthorized software installation, and suspicious connections.

### Risk and Impact

Likelihood: High. Impact: Critical. The major risks are credit-card data theft, malware installation, lateral movement, compromise of multiple stores, financial loss, and reputational damage. The root cause was excessive trust between wireless access and internal corporate systems.

### Recommendations

Use WPA2/WPA3-Enterprise and 802.1X; isolate wireless networks; apply deny-by-default firewall rules; segment POS systems; use NAC where appropriate; deploy IDS/IPS and WIDS/WIPS; centralize identity and logging; restrict administrative privileges; and continuously test segmentation.

### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

### 3. Firesheep and Public Wi-Fi Session Hijacking, 2010

#### 1. Incident Background and Technical Understanding

The assessment describes Firesheep as demonstrating how an attacker on the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The incident highlighted the weakness of protecting only the login page while allowing later session traffic to use unencrypted HTTP.

#### Open Wireless Network

An open Wi-Fi network permits nearby users to connect without strong network-layer authentication. Client isolation is important so that connected users cannot directly communicate with one another.

#### Session-Cookie Protection

Session cookies must be protected with HTTPS and secure cookie attributes. Cookies should use Secure and HttpOnly flags where appropriate, and applications should use short, controlled session lifetimes.

#### HTTPS and HSTS

HTTPS should be enforced across the complete authenticated session, not only during login. HSTS can help prevent downgrade to insecure HTTP when correctly deployed.

#### VPN and User Awareness

A trusted VPN can provide additional protection on untrusted networks. Users should avoid entering sensitive information on suspicious pages, verify HTTPS/certificate warnings, and understand the risks of public Wi-Fi.

#### Risk and Impact

Likelihood: High. Impact: High. Session hijacking can result in account impersonation, unauthorized transactions, privacy violations, and loss of trust. The root cause is exposure of session information over an untrusted network and incomplete transport-layer encryption.

#### Recommendations

Enforce HTTPS everywhere; deploy HSTS; use secure session cookies; implement client isolation; provide secure WPA2/WPA3 access where possible; recommend VPN for sensitive use; disable insecure HTTP redirects; monitor access logs; and educate users about public Wi-Fi threats.

#### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 4. DarkHotel Attacks Through Hotel Wi-Fi Networks

### 1. Incident Background and Technical Understanding

The assessment states that the DarkHotel campaign targeted business executives and government officials through compromised hotel networks. Selected guests were presented with fraudulent software-update prompts that delivered malware. The case demonstrates the security risks of third-party Wi-Fi management, captive portals, insecure update mechanisms, and inadequate monitoring of guest networks.

### Guest Authentication and Captive Portal

Hotel guest authentication should be separated from privileged hotel systems. Captive portals must use secure transport and should not be trusted as a replacement for network segmentation or endpoint security.

### DNS Integrity

DNS manipulation can redirect users to malicious destinations. DNS security controls, protected resolvers, monitoring, and encrypted DNS where appropriate can reduce exposure.

### Third-Party Access and Segmentation

Hotel vendors and service providers should have restricted, monitored access. Guest Wi-Fi, administrative systems, payment systems, surveillance systems, and building-management networks should be segmented.

### Software-Update Security

Software updates should be obtained through trusted vendor channels and verified using cryptographic signatures. Users should not install updates solely because a hotel network displays a prompt.

### Risk and Impact

Likelihood: Medium–High. Impact: Critical. Targeted malware could compromise executive devices, credentials, business information, and privileged accounts. Root causes include untrusted network infrastructure, weak update verification, and insufficient monitoring.

### Recommendations

Use strong guest authentication and segmentation; monitor DNS and wireless infrastructure; restrict vendor access; enforce endpoint protection; require signed and verified updates; use EDR; apply MFA; log privileged activity; and conduct regular third-party security assessments.

### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 5. Marriott Wi-Fi Deauthentication Incident, 2014

### 1. Incident Background and Technical Understanding

The assessment describes an FCC investigation involving equipment used to send Wi-Fi deauthentication messages that prevented guests from using personal hotspots. Marriott agreed to pay a \$600,000 civil penalty. The case demonstrates that IEEE 802.11 management frames can create availability risks when protections are absent and when wireless controls are misused.

### Deauthentication and Availability

Deauthentication frames can force clients to disconnect from an access point. Repeated or malicious use can create denial-of-service conditions and interfere with legitimate connectivity.

### Protected Management Frames

Protected Management Frames (PMF), associated with IEEE 802.11w and required in WPA3 operation, help protect management-frame exchanges from certain spoofing attacks. Deployment should be planned for compatibility and security.

### Wireless Intrusion Detection

WIDS/WIPS can detect abnormal deauthentication activity, unusual management-frame patterns, unauthorized devices, and interference.

### Policy and Legal Risk

Wireless controls should be limited to legitimate security and operational purposes. Acceptable-use policies must define permitted monitoring and interference practices. Unauthorized interference can create regulatory and legal consequences.

### Risk and Impact

Likelihood: High. Impact: Medium–High. The main impact is loss of wireless availability, disruption of customer connectivity, and possible regulatory action. The root cause is inadequate protection against management-frame abuse and improper wireless-control practices.

### Recommendations

Enable PMF where supported; prefer WPA3; deploy WIDS/WIPS; baseline normal wireless behavior; investigate repeated deauthentication events; maintain clear acceptable-use policies; restrict wireless-management privileges; and document legal/regulatory requirements.

### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 6. Fake Wi-Fi Networks at the Republican National Convention, 2016

### 1. Incident Background and Technical Understanding

The assessment states that a security experiment established fake open wireless networks near the event venue and that approximately 1,200 users connected within one day. The event demonstrated that users may trust familiar network names and expose device or identity information when connecting to unknown wireless networks.

#### SSID Trust and Evil-Twin Risk

Attackers can create access points with names resembling legitimate networks. Users may connect automatically or manually without verifying authenticity.

#### Automatic Reconnection

Devices that automatically reconnect to known SSIDs can create opportunities for evil-twin attacks. Organizations should configure managed devices to minimize unsafe automatic connections.

#### Captive Portal and Certificate Validation

A captive portal does not prove that a network is legitimate. Users must still validate the destination and HTTPS certificate warnings. Security education should emphasize that certificate warnings should not be ignored.

#### VPN and Detection

VPN use can protect traffic on untrusted networks, while WIDS/WIPS and wireless surveys can help identify rogue access points.

#### Risk and Impact

Likelihood: High. Impact: High. Risks include credential exposure, device fingerprinting, tracking, malicious redirection, and phishing. The root cause is excessive trust in SSID names and insufficient network-verification controls.

#### Recommendations

Use managed device profiles; disable unnecessary auto-join behavior; deploy WIDS/WIPS; require VPN on untrusted networks; use MFA; educate participants; publish official SSIDs and verification procedures; and provide staff with rogue-AP response procedures.

#### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

### 1. Incident Background and Technical Understanding

The assessment describes close-access targeting of Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

#### Public-Network Authentication

Hotel and event Wi-Fi should be treated as untrusted. Strong enterprise authentication, MFA, and device-based controls reduce credential theft risk.

#### Credential and Device Protection

Passwords should be unique and protected by MFA. Managed devices should use endpoint security, disk encryption, patching, and secure configuration.

#### Device Certificates and VPN

Device certificates can provide stronger device identity, while a correctly configured VPN protects traffic over untrusted networks.

#### Medical Information Protection

Sensitive information should be encrypted in transit and at rest, access should follow least privilege, and logs should record access to sensitive systems.

#### Risk and Impact

Likelihood: Medium–High. Impact: Critical. Compromise could expose sensitive personal and medical information, damage the integrity of anti-doping operations, and create legal and reputational consequences.

#### Recommendations

Require MFA; use managed devices and certificates; enforce VPN; segment sensitive systems; apply EDR; use least privilege; prohibit insecure public-network access to sensitive systems; establish travel-security procedures; and monitor suspicious sign-ins and device activity.

#### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.



## 8. Attempted OPCW Wi-Fi Intrusion, 2018

### 1. Incident Background and Technical Understanding

The assessment states that Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague in April 2018. Equipment intended for a Wi-Fi compromise was found in a vehicle near the organization's premises. The case highlights the importance of protecting wireless networks beyond the physical perimeter.

### RF Exposure and Physical Perimeter

Wireless signals may extend outside buildings. Organizations should perform RF surveys, review access-point placement and transmit power, and assess exposure around physical boundaries.

### Enterprise Wi-Fi Authentication

Enterprise WLANs should use 802.1X with strong EAP configurations, validated certificates, and centralized identity management.

### Rogue Device Detection

WIDS/WIPS and continuous wireless monitoring can identify unauthorized access points, suspicious clients, and unusual RF activity.

### Physical Security and NAC

Physical surveillance can detect close-access equipment, while NAC can enforce device identity and authorization before network access is granted.

### Risk and Impact

Likelihood: Medium. Impact: Critical. A successful compromise could provide a foothold into sensitive organizational systems. Root causes to prevent include weak enterprise authentication, inadequate certificate validation, insufficient wireless monitoring, and lack of physical/RF awareness.

### Recommendations

Use WPA2-Enterprise/WPA3-Enterprise with 802.1X; validate server certificates; deploy WIDS/WIPS; perform periodic RF surveys; use NAC; restrict access by identity/device posture; monitor authentication logs; and integrate wireless alerts with physical security response.

### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 9. Australian Airport and In-Flight Evil-Twin Case, 2024

### 1. Incident Background and Technical Understanding

The assessment states that the Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users connecting to fraudulent access points.

#### SSID Impersonation

An evil-twin access point can use a legitimate-looking SSID to attract users. SSID appearance alone is not proof of authenticity.

#### Captive Portal and Automatic Connection

Fake captive portals can collect credentials or personal information. Automatic connection behavior can increase exposure to fraudulent networks.

#### Certificate Warnings

Users should never bypass browser certificate warnings. HTTPS and valid certificates help users distinguish secure connections, although they do not by themselves prove Wi-Fi legitimacy.

#### Passenger-Data Exposure

Airports should minimize collection of personal data, secure portal sessions, protect administrative accounts, and monitor suspicious traffic and access points.

#### Risk and Impact

Likelihood: High. Impact: High. Possible consequences include credential theft, personal-data exposure, phishing, and follow-on account compromise. Root causes include SSID trust, weak verification, and insufficient rogue-AP detection.

#### Recommendations

Deploy rogue-AP detection; publish clear official SSIDs; use secure captive portals; enforce HTTPS; use MFA; educate passengers and staff; provide procedures for reporting suspicious networks; monitor wireless infrastructure; and rapidly investigate cloned SSIDs.

#### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

## 10. Network Rail Public Wi-Fi Portal Compromise, 2024

### 1. Incident Background and Technical Understanding

The assessment states that on September 25, 2024, public Wi-Fi services at 19 major UK railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account, after which the affected services were suspended while the incident was investigated. This case emphasizes privileged-account security and supplier/access-control governance.

#### Privileged Access Management

Administrator accounts should be separated from normal user accounts, protected with MFA, and granted only the permissions required for their duties. Privileged sessions should be logged and monitored.

#### Captive-Portal Security

The portal-management platform should be securely configured, patched, and protected against unauthorized administrative access. Changes to public-facing content should be controlled and traceable.

#### Third-Party Supplier Access

Suppliers should receive least-privilege, time-limited access with strong authentication and clear accountability. Shared administrator accounts should be avoided.

#### Logging and Change Approval

Administrative logins, configuration changes, content changes, and failed authentication attempts should be centrally logged. High-impact changes should require approval and review.

#### Risk and Impact

Likelihood: Medium–High. Impact: High. Misuse of a legitimate administrator account can alter public services, damage reputation, disrupt operations, and potentially provide a path to deeper compromise. The root cause is inadequate privileged-access governance and monitoring.

#### Recommendations

Enforce MFA for all privileged users; deploy PAM; use unique administrator accounts; implement role-based access control; require change approval; maintain immutable audit logs; monitor privileged activity; restrict supplier access; conduct regular access reviews; test incident-response procedures; and rapidly disable compromised accounts.

#### Suggested Safe Validation / Evidence

- Review wireless configuration and encryption settings in the authorized environment.
- Verify authentication, segmentation and firewall rules using configuration review and approved vulnerability scanners.
- Review WIDS/WIPS, authentication, DHCP, DNS and firewall logs for abnormal activity.
- Confirm that sensitive services require HTTPS/TLS, MFA and appropriate access controls.
- Document screenshots, configuration evidence, log entries and risk ratings without collecting real users' credentials or sensitive data.

